Parecer executivo à Diretoria da ANDI

Assunto: perda esperada com incidentes cibernéticos em 2026 e avaliação do pacote de controles de R$ 8 milhões por ano **De:** Grupo 5 — equipe de risco | **Data:** dezembro de 2026

RASCUNHO PARA REVISÃO DO GRUPO (Questão 15). Produzido com apoio de IA; ver `memorial_ia.md`.

1. Quanto a ANDI deve perder em 2026?

Mantida a situação atual, a perda esperada com incidentes cibernéticos em 2026 é de **R$ 31 milhões**. É praticamente o que a Agência perdeu, em média, em cada um dos três últimos anos.

O valor pode ser maior. Em um ano a cada vinte, a perda passaria de **R$ 37 milhões**; em um ano a cada cem, de **R$ 40 milhões**. Nos anos ruins (os 5% piores), a perda média seria de **R$ 39 milhões**. A chance de a perda superar R$ 30 milhões é de cerca de 65%.

O incidente típico custa cerca de R$ 32 mil, mas um em cada dez incidentes responde por metade do valor perdido. O número de ataques cresce cerca de 5% ao ano.

2. O pacote de controles vale a pena?

Sim. Recomendamos aprovar o pacote.

Com cobertura de patches de 95%, 12 horas de treinamento e SOC dedicado em todas as unidades, a perda esperada cai de R$ 31 milhões para **R$ 9 milhões** por ano.

	Hoje	Com o pacote
Perda esperada no ano	R$ 31 mi	R$ 9 mi
Perda superada em 1 ano a cada 20	R$ 37 mi	R$ 12 mi
Perda média nos 5% piores anos	R$ 39 mi	R$ 14 mi
Chance de perder mais de R$ 30 mi	65%	praticamente zero

- O pacote evita **R$ 22 milhões** de perda por ano e custa R$ 8 milhões: cada real investido retorna R$ 2,75, um retorno líquido de **175%**.
- Ele reduz o risco de cauda em cerca de dois terços, o que conta para o dimensionamento de reservas e de seguro.
- Em 100 mil anos simulados, não houve nenhum em que a Agência ficasse pior com o pacote, já contado o custo.
- O pacote continuaria se pagando mesmo que custasse até R$ 22 milhões por ano.

O ganho vem de três efeitos: menos ataques (30% a menos), menor proporção de ataques que viram prejuízo (de 42% para 19%) e prejuízos menores, por detecção mais rápida. O segundo é o maior e depende sobretudo do SOC dedicado.

3. Quão confiáveis são esses números?

A recomendação é robusta; os valores exatos, menos. Testamos a decisão com premissas piores (menos ataques e perdas menos dispersas do que estimamos) e o pacote se pagou em todos os casos, com retorno mínimo de 109%. Para a recomendação mudar, o benefício teria de ser quase dois terços menor do que o estimado.

Limitações que a Diretoria deve conhecer:

1. **O modelo tende a subestimar a perda.** Ao compará-lo com o processo que gerou os dados, a perda esperada verdadeira ficou cerca de 8% acima da nossa estimativa (R$ 34 milhões, e não R$ 31 milhões), e a diferença aumenta nos cenários extremos. Recomendamos planejar reservas com margem de pelo menos 10% sobre os valores deste parecer.
2. **Trabalhamos com apenas três anos e 24 unidades.** O efeito de cada controle isolado, em especial o da cobertura de patches, foi estimado com pouca precisão. Confiamos no efeito do pacote inteiro mais do que na contribuição de cada item.
3. **O histórico foi reconstruído, não observado.** Os dados vêm de um modelo construído por especialistas; as conclusões valem na medida em que ele representa a realidade da Agência.
4. **Eventos sem precedente não estão no modelo.** Uma campanha coordenada como a de abril de 2025 não foi incluída na projeção de 2026, e ataques de um tipo novo ou muito maiores do que os já vistos ficam fora do alcance do método.
5. **Supomos que os controles funcionarão como nas unidades que já os têm.** Um SOC novo pode levar meses para atingir o desempenho dos atuais; o primeiro ano pode render menos que o estimado.

Encaminhamento. Aprovar o pacote, começando pelas onze unidades sem SOC, onde mais da metade dos ataques vira perda; contratar cobertura de detecção fora do expediente, onde hoje o tempo de detecção é cerca de 50% maior; e revisar esta análise daqui a doze meses, com os dados reais de 2026.